

Esercitazione Decrittazione Tramite JtR

```
(kali㉿kali)-[~]
$ john --format=raw-md5 /home/kali/Desktop/hash.txt
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
password      (?)
password      (?)
abc123        (?)
letmein       (?)
Proceeding with incremental:ASCII
charley       (?)
5g 0:00:00:00 DONE 3/3 (2024-05-21 14:00) 20.00g/s 712632p/s 712632c/s 715704C/s stevy13..chertsu
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~]
$ john --show --format=raw-md5 /home/kali/Desktop/hash.txt
?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left

(kali㉿kali)-[~]
$
```

Utilizzando una MySQL injection siamo riusciti a recuperare una lista di record segnati come password, Hashati in formato MD5, utilizzando uno dei tool che abbiamo a disposizione procediamo a ripristinare in chiaro le password ottenute, il tool in questione per l'esercitazione è Jhon the Ripper, grazie al cui inserendo la tipologia della chiave di Hashing e un file con contenuto da tradurre, riusciamo ad ottenere le password in chiaro utilizzando diversi tipologie di lettura, nei primi 4 record vediamo un confronto con un database di jhon, mentre per la 4 password notiamo un bruteforce tramite tabella ASCII in questo caso il controllo viene fatto lettera per lettera fino a quando non viene trovato il risultato richiesto. A seguito è presente una breve descrizione delle funzioni e descrizione dei tool utilizzati SQLi e JtR.

SQL INJECTION

SQL INJECTION (SQLi) è una vulnerabilità informatica che permette a malintenzionati di iniettare codice SQL dannoso in un'applicazione web. Questo codice può essere utilizzato per:

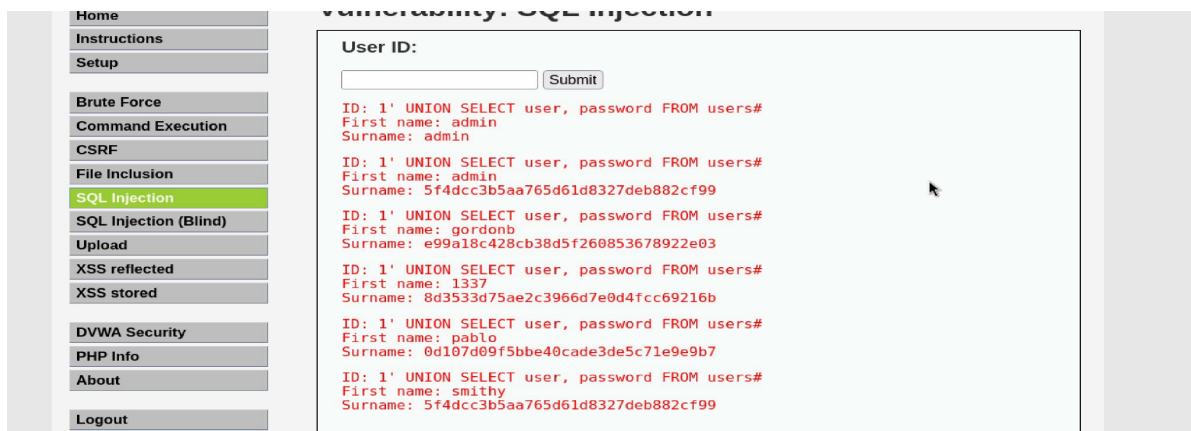
- **Rubare dati sensibili:** come nomi utente, password, informazioni finanziarie o altri dati riservati memorizzati nel database.
- **Modificare dati:** ad esempio, per alterare il saldo di un conto bancario o il risultato di un'elezione.
- **Interrompere il funzionamento dell'applicazione:** rendendola inaccessibile agli utenti legittimi.

SQLi viene sfruttata **tramite la mancata convalida e sanificazione dell'input dell'utente**. In parole semplici, l'applicazione non controlla correttamente i dati inseriti dagli utenti nei campi di input, come moduli web o barre di ricerca.

Se un utente inserisce codice SQL dannoso in uno di questi campi, questo codice può essere eseguito dal database come se fosse una query SQL legittima.

Esistono diversi tipi di attacchi SQLi, ma alcuni dei più comuni includono:

- **SQLi basata su stringhe:** l'attaccante inserisce codice SQL dannoso in una stringa di input, come un nome utente o una password.
- **SQLi basata su query:** l'attaccante modifica una query SQL esistente aggiungendo codice dannoso.
- **SQLi non in banda:** l'attaccante sfrutta un bug nell'applicazione per inviare codice SQL al database tramite un metodo diverso da una richiesta HTTP.



John the Ripper

John the Ripper è un programma open source per il cracking di password ampiamente utilizzato per recuperare le password perse o decifrare password rubate. Funziona utilizzando una varietà di metodi per tentare di indovinare la password corretta, tra cui:

- **Attacco basato su dizionario:** John the Ripper prova a indovinare la password utilizzando parole da un dizionario. Il programma include un dizionario di parole predefinito, ma è possibile utilizzare anche dizionari personalizzati.
- **Attacco basato sulla forza bruta:** John the Ripper prova tutte le combinazioni possibili di caratteri fino a trovare la password corretta. Questo metodo può essere molto lento, ma è garantito che funzioni se la password è sufficientemente corta e complessa.
- **Attacco ibrido:** John the Ripper combina attacchi basati su dizionario e attacchi basati sulla forza bruta per migliorare le sue possibilità di successo.
- **Attacco basato su regole:** John the Ripper può utilizzare regole personalizzate per generare potenziali password da provare. Ad esempio, una regola potrebbe generare password che utilizzano una combinazione di lettere maiuscole, minuscole, numeri e simboli.

Oltre a questi metodi di cracking di base, John the Ripper supporta anche una varietà di funzionalità avanzate, tra cui:

- **Supporto per diversi Hash di password:** John the Ripper può crackare password memorizzate in una varietà di formati di Hash.
- **Attacco con maschera:** può essere utilizzato per crackare password che soddisfano una determinata maschera. Ad esempio, una maschera potrebbe specificare che la password deve essere lunga 8 caratteri e contenere almeno una lettera maiuscola e un numero.
- **Attacco a dizionario personalizzato:** può utilizzare dizionari personalizzati di parole o frasi.
- **Attacco basato su regole personalizzate:** può utilizzare regole personalizzate per generare potenziali password da provare.
- **Attacco con GPU:** può utilizzare la GPU di un computer per accelerare il processo di cracking delle password.